

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2022.2

STRM Guidance: https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/

Focal Document: US - Securities and Exchange Commission (SEC) Cybersecurity Rule (2023)

Focal Document URL: https://www.sec.gov/files/rules/final/2023/33-11216.pdf

Published STRM URL: https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-sec-cybersecurity-rule-2023.pdf

| FDE #             | FDE Name | Focal Document Element (FDE) Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | STRM Rationale | STRM Relationship | SCF Control                                        | SCF #    | Secure Controls Framework (SCF) Control Description                                                                                                                                                                                                                                                                                                                                                       | Strength of Relationship | Notes |
|-------------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|-------------------|----------------------------------------------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|-------|
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Materiality Determination                          | GOV-16   | Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.                                                                                                                                                                                                                                                                                                 | 5                        |       |
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Material Risks                                     | GOV-16.1 | Mechanisms exist to define criteria necessary to designate a risk as a material risk.                                                                                                                                                                                                                                                                                                                     | 5                        |       |
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Material Threats                                   | GOV-16.2 | Mechanisms exist to define criteria necessary to designate a threat as a material threat.                                                                                                                                                                                                                                                                                                                 | 5                        |       |
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Subset Of         | Risk Management Program                            | RSK-01   | Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:<br>(1) The organization's Enterprise Risk Management (ERM); and<br>(2) Industry-recognized cybersecurity risk management practices.                                                                                                                              | 10                       |       |
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Framing                                       | RSK-01.1 | Mechanisms exist to identify:<br>(1) Assumptions affecting risk assessments, risk response and risk monitoring;<br>(2) Constraints affecting risk assessments, risk response and risk monitoring;<br>(3) The organizational risk tolerance; and<br>(4) Priorities, benefits and trade-offs considered by the organization for managing risk.                                                              | 5                        |       |
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk-Based Security Categorization                 | RSK-02   | Mechanisms exist to categorize Technology Assets, Applications, Services and/or Data (TAASD) in accordance with applicable laws, regulations and contractual obligations that:<br>(1) Document the security categorization results (including supporting rationale) in the security plan for systems; and<br>(2) Ensure the security categorization decision is reviewed and approved by the asset owner. | 5                        |       |
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Catalog                                       | RSK-03.1 | Mechanisms exist to develop and keep current a catalog of applicable risks associated with the organization's business operations and technologies in use.                                                                                                                                                                                                                                                | 5                        |       |
| 17 CFR 229.105(a) | N/A      | Where appropriate, provide under the caption "Risk Factors" a discussion of the material factors that make an investment in the registrant or offering speculative or risky. This discussion must be organized logically with relevant headings and each risk factor should be set forth under a subcaption that adequately describes the risk. The presentation of risks that could apply generically to any registrant or any offering is discouraged, but to the extent generic risk factors are presented, disclose them at the end of the risk factor section under the caption "General Risk Factors."                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Register                                      | RSK-04.1 | Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.                                                                                                                                                                                                                                                                                                          | 5                        |       |
| 17 CFR 229.105(b) | N/A      | Concise explain how each risk affects the registrant or the securities being offered. If the discussion is longer than 15 pages, include in the forepart of the prospectus or annual report, as applicable, a series of concise, bulleted or numbered statements that is no more than two pages summarizing the principal factors that make an investment in the registrant or offering speculative or risky. If the risk factor discussion is included in a registration statement, it must immediately follow the summary section required by § 229.503 (Item 503 of Regulation S-K). If you do not include a summary section, the risk factor section must immediately follow the cover page of the prospectus or the pricing information section that immediately follows the cover page. Pricing information means price and price-related information that you may omit from the prospectus in an effective registration statement based on Rule 430A (§ 230.430A of this chapter). The registrant must furnish this information in plain English. See § 230.421(d) of Regulation C of this chapter. | Functional     | Intersects With   | Materiality Determination                          | GOV-16   | Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.                                                                                                                                                                                                                                                                                                 | 5                        |       |
| 17 CFR 229.105(b) | N/A      | Concise explain how each risk affects the registrant or the securities being offered. If the discussion is longer than 15 pages, include in the forepart of the prospectus or annual report, as applicable, a series of concise, bulleted or numbered statements that is no more than two pages summarizing the principal factors that make an investment in the registrant or offering speculative or risky. If the risk factor discussion is included in a registration statement, it must immediately follow the summary section required by § 229.503 (Item 503 of Regulation S-K). If you do not include a summary section, the risk factor section must immediately follow the cover page of the prospectus or the pricing information section that immediately follows the cover page. Pricing information means price and price-related information that you may omit from the prospectus in an effective registration statement based on Rule 430A (§ 230.430A of this chapter). The registrant must furnish this information in plain English. See § 230.421(d) of Regulation C of this chapter. | Functional     | Intersects With   | Material Risks                                     | GOV-16.1 | Mechanisms exist to define criteria necessary to designate a risk as a material risk.                                                                                                                                                                                                                                                                                                                     | 5                        |       |
| 17 CFR 229.105(b) | N/A      | Concise explain how each risk affects the registrant or the securities being offered. If the discussion is longer than 15 pages, include in the forepart of the prospectus or annual report, as applicable, a series of concise, bulleted or numbered statements that is no more than two pages summarizing the principal factors that make an investment in the registrant or offering speculative or risky. If the risk factor discussion is included in a registration statement, it must immediately follow the summary section required by § 229.503 (Item 503 of Regulation S-K). If you do not include a summary section, the risk factor section must immediately follow the cover page of the prospectus or the pricing information section that immediately follows the cover page. Pricing information means price and price-related information that you may omit from the prospectus in an effective registration statement based on Rule 430A (§ 230.430A of this chapter). The registrant must furnish this information in plain English. See § 230.421(d) of Regulation C of this chapter. | Functional     | Intersects With   | Material Threats                                   | GOV-16.2 | Mechanisms exist to define criteria necessary to designate a threat as a material threat.                                                                                                                                                                                                                                                                                                                 | 5                        |       |
| 17 CFR 229.105(b) | N/A      | Concise explain how each risk affects the registrant or the securities being offered. If the discussion is longer than 15 pages, include in the forepart of the prospectus or annual report, as applicable, a series of concise, bulleted or numbered statements that is no more than two pages summarizing the principal factors that make an investment in the registrant or offering speculative or risky. If the risk factor discussion is included in a registration statement, it must immediately follow the summary section required by § 229.503 (Item 503 of Regulation S-K). If you do not include a summary section, the risk factor section must immediately follow the cover page of the prospectus or the pricing information section that immediately follows the cover page. Pricing information means price and price-related information that you may omit from the prospectus in an effective registration statement based on Rule 430A (§ 230.430A of this chapter). The registrant must furnish this information in plain English. See § 230.421(d) of Regulation C of this chapter. | Functional     | Subset Of         | Security, Compliance & Resilience Status Reporting | GOV-17   | Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.                                                                                                                                                                                                                      | 10                       |       |
| 17 CFR 229.105(b) | N/A      | Concise explain how each risk affects the registrant or the securities being offered. If the discussion is longer than 15 pages, include in the forepart of the prospectus or annual report, as applicable, a series of concise, bulleted or numbered statements that is no more than two pages summarizing the principal factors that make an investment in the registrant or offering speculative or risky. If the risk factor discussion is included in a registration statement, it must immediately follow the summary section required by § 229.503 (Item 503 of Regulation S-K). If you do not include a summary section, the risk factor section must immediately follow the cover page of the prospectus or the pricing information section that immediately follows the cover page. Pricing information means price and price-related information that you may omit from the prospectus in an effective registration statement based on Rule 430A (§ 230.430A of this chapter). The registrant must furnish this information in plain English. See § 230.421(d) of Regulation C of this chapter. | Functional     | Intersects With   | Risk-Based Security Categorization                 | RSK-02   | Mechanisms exist to categorize Technology Assets, Applications, Services and/or Data (TAASD) in accordance with applicable laws, regulations and contractual obligations that:<br>(1) Document the security categorization results (including supporting rationale) in the security plan for systems; and<br>(2) Ensure the security categorization decision is reviewed and approved by the asset owner. | 5                        |       |
| 17 CFR 229.105(b) | N/A      | Concise explain how each risk affects the registrant or the securities being offered. If the discussion is longer than 15 pages, include in the forepart of the prospectus or annual report, as applicable, a series of concise, bulleted or numbered statements that is no more than two pages summarizing the principal factors that make an investment in the registrant or offering speculative or risky. If the risk factor discussion is included in a registration statement, it must immediately follow the summary section required by § 229.503 (Item 503 of Regulation S-K). If you do not include a summary section, the risk factor section must immediately follow the cover page of the prospectus or the pricing information section that immediately follows the cover page. Pricing information means price and price-related information that you may omit from the prospectus in an effective registration statement based on Rule 430A (§ 230.430A of this chapter). The registrant must furnish this information in plain English. See § 230.421(d) of Regulation C of this chapter. | Functional     | Intersects With   | Risk Catalog                                       | RSK-03.1 | Mechanisms exist to develop and keep current a catalog of applicable risks associated with the organization's business operations and technologies in use.                                                                                                                                                                                                                                                | 5                        |       |

**NIST IR 8477-Based Set Theory Relationship Mapping (STRM)**

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - Securities and Exchange Commission (SEC) Cybersecurity Rule (2023)**

Focal Document URL: <https://www.sec.gov/files/rules/final/2023/33-11216.pdf>

Published STRM URL: <https://content.securecontrolsframework.com/12/m/scf-strm-usa-federal-sec-cybersecurity-rule-2023.pdf>

| FDE #                   | FDE Name | Focal Document Element (FDE) Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | STRM Rationale | STRM Relationship | SCF Control                                                     | SCF #    | Secure Controls Framework (SCF) Control Description                                                                                                                                                                                                                                                                              | Strength of Relationship | Notes |
|-------------------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|-------------------|-----------------------------------------------------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|-------|
| 17 CFR 229.105(b)       | N/A      | Concise explain how each risk affects the registrant or the securities being offered. If the discussion is longer than 15 pages, include in the forefront of the prospectus or annual report, as applicable, a series of concise, bulleted or numbered statements that is no more than two pages summarizing the principal factors that make an investment in the registrant or offering speculative or risky. If the risk factor discussion is included in a registration statement, it must immediately follow the summary section required by § 229.503 (Item 503 of Regulation S-K). If you do not include a summary section, the risk factor section must immediately follow the cover page of the prospectus or the pricing information section that immediately follows the cover page. Pricing information means price and price-related information that you may omit from the prospectus in an effective registration statement based on Rule 430A (§ 230.430A of this chapter). The registrant must furnish this information in plain English. See § 230.421(d) of Regulation C of this chapter. | Functional     | Intersects With   | Risk Register                                                   | RSK-04.1 | Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.                                                                                                                                                                                                                                 | 5                        |       |
| 17 CFR 229.106(a)       | N/A      | Definitions. For purposes of this section: Cybersecurity incident means an unauthorized occurrence, or a series of related unauthorized occurrences, on or conducted through a registrant's information systems that jeopardizes the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Cybersecurity threat means any potential unauthorized occurrence on or conducted through a registrant's information systems that may result in adverse effects on the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Information systems means electronic information resources, owned or used by the registrant, including physical or virtual infrastructure controlled by such information resources, or components thereof, organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of the registrant's information to maintain or support the registrant's operations.                                                  | Functional     | Intersects With   | Materiality Determination                                       | GOV-16   | Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.                                                                                                                                                                                                                        | 5                        |       |
| 17 CFR 229.106(a)       | N/A      | Definitions. For purposes of this section: Cybersecurity incident means an unauthorized occurrence, or a series of related unauthorized occurrences, on or conducted through a registrant's information systems that jeopardizes the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Cybersecurity threat means any potential unauthorized occurrence on or conducted through a registrant's information systems that may result in adverse effects on the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Information systems means electronic information resources, owned or used by the registrant, including physical or virtual infrastructure controlled by such information resources, or components thereof, organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of the registrant's information to maintain or support the registrant's operations.                                                  | Functional     | Intersects With   | Material Threats                                                | GOV-16.2 | Mechanisms exist to define criteria necessary to designate a threat as a material threat.                                                                                                                                                                                                                                        | 5                        |       |
| 17 CFR 229.106(a)       | N/A      | Definitions. For purposes of this section: Cybersecurity incident means an unauthorized occurrence, or a series of related unauthorized occurrences, on or conducted through a registrant's information systems that jeopardizes the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Cybersecurity threat means any potential unauthorized occurrence on or conducted through a registrant's information systems that may result in adverse effects on the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Information systems means electronic information resources, owned or used by the registrant, including physical or virtual infrastructure controlled by such information resources, or components thereof, organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of the registrant's information to maintain or support the registrant's operations.                                                  | Functional     | Intersects With   | Risk Assessment                                                 | RSK-04   | Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).                                            | 5                        |       |
| 17 CFR 229.106(a)       | N/A      | Definitions. For purposes of this section: Cybersecurity incident means an unauthorized occurrence, or a series of related unauthorized occurrences, on or conducted through a registrant's information systems that jeopardizes the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Cybersecurity threat means any potential unauthorized occurrence on or conducted through a registrant's information systems that may result in adverse effects on the confidentiality, integrity, or availability of a registrant's information systems or any information residing therein. Information systems means electronic information resources, owned or used by the registrant, including physical or virtual infrastructure controlled by such information resources, or components thereof, organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of the registrant's information to maintain or support the registrant's operations.                                                  | Functional     | Intersects With   | Threat Analysis                                                 | THR-10   | Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.                                                                                                                                                                             | 5                        |       |
| 17 CFR 229.106(b)       | N/A      | <b>Risk management and strategy.</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Functional     | No Relationship   | N/A                                                             | N/A      | N/A                                                                                                                                                                                                                                                                                                                              | 0                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Subset Of         | Risk Management Program                                         | RSK-01   | Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices. Mechanisms exist to identify:                             | 10                       |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Framing                                                    | RSK-01.1 | (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.                               | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Tolerance                                                  | RSK-01.3 | Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.                                                                                                                                                                                                                             | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Threshold                                                  | RSK-01.4 | Mechanisms exist to define organizational risk threshold, the level of risk exposure above which risks are addressed and below which risks may be accepted.                                                                                                                                                                      | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Appetite                                                   | RSK-01.5 | Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.                                                                                                                                                                            | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Impact-Level Prioritization                                     | RSK-02.1 | Mechanisms exist to prioritize the impact level for Technology Assets, Applications and/or Services (TAAS) to prevent potential disruptions.                                                                                                                                                                                     | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Identification                                             | RSK-03   | Mechanisms exist to identify and document risks, both internal and external.                                                                                                                                                                                                                                                     | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Assessment                                                 | RSK-04   | Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).                                            | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Ranking                                                    | RSK-05   | Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities that is based on industry-recognized practices.                                                                                                                                                                              | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Remediation                                                | RSK-06   | Mechanisms exist to remediate risks to an acceptable level.                                                                                                                                                                                                                                                                      | 5                        |       |
| 17 CFR 229.106(b)(1)    | N/A      | Describe the registrant's processes, if any, for assessing, identifying, and managing material risks from cybersecurity threats in sufficient detail for a reasonable investor to understand those processes. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Response                                                   | RSK-06.1 | Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or                                                                                                                                            | 5                        |       |
| 17 CFR 229.106(b)(1)(i) | N/A      | Whether and how any such processes have been integrated into the registrant's overall risk management system or processes;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Functional     | Intersects With   | Operationalizing Security, Compliance & Resilience Capabilities | GOV-15   | Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.                                                                                                                     | 5                        |       |
| 17 CFR 229.106(b)(1)(i) | N/A      | Whether and how any such processes have been integrated into the registrant's overall risk management system or processes;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Functional     | Subset Of         | Risk Management Program                                         | RSK-01   | Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:                                                                                                                                                                                         | 10                       |       |
| 17 CFR 229.106(b)(1)(i) | N/A      | Whether and how any such processes have been integrated into the registrant's overall risk management system or processes;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Functional     | Intersects With   | Risk Framing                                                    | RSK-01.1 | Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk. | 5                        |       |
| 17 CFR 229.106(b)(1)(i) | N/A      | Whether and how any such processes have been integrated into the registrant's overall risk management system or processes;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Functional     | Intersects With   | Risk Tolerance                                                  | RSK-01.3 | Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.                                                                                                                                                                                                                             | 5                        |       |
| 17 CFR 229.106(b)(1)(i) | N/A      | Whether and how any such processes have been integrated into the registrant's overall risk management system or processes;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Functional     | Intersects With   | Risk Threshold                                                  | RSK-01.4 | Mechanisms exist to define organizational risk threshold, the level of risk exposure above which risks are addressed and below which risks may be accepted.                                                                                                                                                                      | 5                        |       |

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - Securities and Exchange Commission (SEC) Cybersecurity Rule (2023)**

Focal Document URL: <https://www.sec.gov/files/rules/final/2023/33-11216.pdf>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-sec-cybersecurity-rule-2023.pdf>

| FDE #                     | FDE Name | Focal Document Element (FDE) Description                                                                                                                                                                                                                                                                                                 | STRM Rationale | STRM Relationship | SCF Control                                                               | SCF #    | Secure Controls Framework (SCF) Control Description                                                                                                                                                                                                                                                            | Strength of Relationship | Notes |
|---------------------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|-------------------|---------------------------------------------------------------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|-------|
| 17 CFR 229.106(b)(1)(i)   | N/A      | Whether and how any such processes have been integrated into the registrant's overall risk management system or processes;                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Appetite                                                             | RSK-01.5 | Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.                                                                                                                                                          | 5                        |       |
| 17 CFR 229.106(b)(1)(i)   | N/A      | Whether and how any such processes have been integrated into the registrant's overall risk management system or processes;                                                                                                                                                                                                               | Functional     | Intersects With   | Risk Assessment                                                           | RSK-04   | Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).                          | 5                        |       |
| 17 CFR 229.106(b)(1)(ii)  | N/A      | Whether the registrant engages assessors, consultants, auditors, or other third parties in connection with any such processes; and                                                                                                                                                                                                       | Functional     | Intersects With   | Assigned Security, Compliance & Resilience Responsibilities               | GOV-04   | Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPI).                                                                             | 5                        |       |
| 17 CFR 229.106(b)(1)(ii)  | N/A      | Whether the registrant engages assessors, consultants, auditors, or other third parties in connection with any such processes; and                                                                                                                                                                                                       | Functional     | Intersects With   | Competency Requirements for Security-Related Positions                    | HRS-03.2 | Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.                                                                                                                                                                          | 5                        |       |
| 17 CFR 229.106(b)(1)(ii)  | N/A      | Whether the registrant engages assessors, consultants, auditors, or other third parties in connection with any such processes; and                                                                                                                                                                                                       | Functional     | Intersects With   | Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix | TPM-05.4 | Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).                 | 5                        |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Intersects With   | Supply Chain Risk Management (SCRM) Plan                                  | RSK-09   | Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans. | 5                        |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Intersects With   | Steering Committee & Program Oversight                                    | GOV-01.1 | Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.                                    | 5                        |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Intersects With   | Status Reporting To Governing Body                                        | GOV-01.2 | Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPI).                                                                       | 5                        |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Intersects With   | Supply Chain Risk Assessment                                              | RSK-09.1 | Mechanisms exist to periodically assess supply chain risks associated with Technology Assets, Applications and/or Services (TAAS).                                                                                                                                                                             | 5                        |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Subset Of         | Third-Party Management                                                    | TPM-01   | Mechanisms exist to facilitate the implementation of third-party management controls.                                                                                                                                                                                                                          | 10                       |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Intersects With   | Third-Party Criticality Assessments                                       | TPM-02   | Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment process relative to their importance in supporting the delivery of high-value services.                                     | 5                        |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Intersects With   | Supply Chain Risk Management (SCRM)                                       | TPM-03   | Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and (2) Take appropriate remediation actions to minimize the organization's exposure to those risks and threats, as necessary.                              | 5                        |       |
| 17 CFR 229.106(b)(1)(iii) | N/A      | Whether the registrant has processes to oversee and identify such risks from cybersecurity threats associated with its use of any third-party service provider.                                                                                                                                                                          | Functional     | Intersects With   | Third-Party Contract Requirements                                         | TPM-05   | Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).                                                     | 5                        |       |
| 17 CFR 229.106(b)(2)      | N/A      | Describe whether any risks from cybersecurity threats, including as a result of any previous cybersecurity incidents, have materially affected or are reasonably likely to materially affect the registrant, including its business strategy, results of operations, or financial condition and if so, how.                              | Functional     | Subset Of         | Materiality Determination                                                 | GOV-16   | Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.                                                                                                                                                                                                      | 10                       |       |
| 17 CFR 229.106(b)(2)      | N/A      | Describe whether any risks from cybersecurity threats, including as a result of any previous cybersecurity incidents, have materially affected or are reasonably likely to materially affect the registrant, including its business strategy, results of operations, or financial condition and if so, how.                              | Functional     | Intersects With   | Material Risks                                                            | GOV-16.1 | Mechanisms exist to define criteria necessary to designate a risk as a material risk.                                                                                                                                                                                                                          | 5                        |       |
| 17 CFR 229.106(b)(2)      | N/A      | Describe whether any risks from cybersecurity threats, including as a result of any previous cybersecurity incidents, have materially affected or are reasonably likely to materially affect the registrant, including its business strategy, results of operations, or financial condition and if so, how.                              | Functional     | Intersects With   | Material Threats                                                          | GOV-16.2 | Mechanisms exist to define criteria necessary to designate a threat as a material threat.                                                                                                                                                                                                                      | 5                        |       |
| 17 CFR 229.106(c)         | N/A      | Governance                                                                                                                                                                                                                                                                                                                               | Functional     | No Relationship   | N/A                                                                       | N/A      | N/A                                                                                                                                                                                                                                                                                                            | 0                        |       |
| 17 CFR 229.106(c)(1)      | N/A      | Describe the board of directors' oversight of risks from cybersecurity threats. If applicable, identify any board committee or subcommittee responsible for the oversight of risks from cybersecurity threats and describe the processes by which the board or such committee is informed about such risks.                              | Functional     | Subset Of         | Steering Committee & Program Oversight                                    | GOV-01.1 | Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.                                    | 10                       |       |
| 17 CFR 229.106(c)(1)      | N/A      | Describe the board of directors' oversight of risks from cybersecurity threats. If applicable, identify any board committee or subcommittee responsible for the oversight of risks from cybersecurity threats and describe the processes by which the board or such committee is informed about such risks.                              | Functional     | Intersects With   | Status Reporting To Governing Body                                        | GOV-01.2 | Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPI).                                                                       | 5                        |       |
| 17 CFR 229.106(c)(1)      | N/A      | Describe the board of directors' oversight of risks from cybersecurity threats. If applicable, identify any board committee or subcommittee responsible for the oversight of risks from cybersecurity threats and describe the processes by which the board or such committee is informed about such risks.                              | Functional     | Intersects With   | Assigned Security, Compliance & Resilience Responsibilities               | GOV-04   | Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPI).                                                                             | 5                        |       |
| 17 CFR 229.106(c)(1)      | N/A      | Describe the board of directors' oversight of risks from cybersecurity threats. If applicable, identify any board committee or subcommittee responsible for the oversight of risks from cybersecurity threats and describe the processes by which the board or such committee is informed about such risks.                              | Functional     | Intersects With   | Stakeholder Accountability Structure                                      | GOV-04.1 | Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.                                                      | 5                        |       |
| 17 CFR 229.106(c)(1)      | N/A      | Describe the board of directors' oversight of risks from cybersecurity threats. If applicable, identify any board committee or subcommittee responsible for the oversight of risks from cybersecurity threats and describe the processes by which the board or such committee is informed about such risks.                              | Functional     | Intersects With   | Authoritative Chain of Command                                            | GOV-04.2 | Mechanisms exist to establish an authoritative chain of command with clear lines of communication to remove ambiguity from individuals and teams related to managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.                                                              | 5                        |       |
| 17 CFR 229.106(c)(2)      | N/A      | Describe management's role in assessing and managing the registrant's material risks from cybersecurity threats. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                         | Functional     | Intersects With   | Steering Committee & Program Oversight                                    | GOV-01.1 | Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.                                    | 5                        |       |
| 17 CFR 229.106(c)(2)      | N/A      | Describe management's role in assessing and managing the registrant's material risks from cybersecurity threats. In providing such disclosure, a registrant should address, as applicable, the following non-exclusive list of disclosure items:                                                                                         | Functional     | Subset Of         | Materiality Determination                                                 | GOV-16   | Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.                                                                                                                                                                                                      | 10                       |       |
| 17 CFR 229.106(c)(2)(i)   | N/A      | Whether and which management positions or committees are responsible for assessing and managing such risks, and the relevant expertise of such persons or members in such detail as necessary to fully describe the nature of the expertise;                                                                                             | Functional     | Subset Of         | Steering Committee & Program Oversight                                    | GOV-01.1 | Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.                                    | 10                       |       |
| 17 CFR 229.106(c)(2)(i)   | N/A      | Whether and which management positions or committees are responsible for assessing and managing such risks, and the relevant expertise of such persons or members in such detail as necessary to fully describe the nature of the expertise;                                                                                             | Functional     | Intersects With   | Assigned Security, Compliance & Resilience Responsibilities               | GOV-04   | Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPI).                                                                             | 5                        |       |
| 17 CFR 229.106(c)(2)(ii)  | N/A      | The processes by which such persons or committees are informed about and monitor the prevention, detection, mitigation, and remediation of cybersecurity incidents; and                                                                                                                                                                  | Functional     | Subset Of         | Status Reporting To Governing Body                                        | GOV-01.2 | Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPI).                                                                       | 10                       |       |
| 17 CFR 229.106(c)(2)(iii) | N/A      | Whether such persons or committees report information about such risks to the board of directors or a committee or subcommittee of the board of directors.                                                                                                                                                                               | Functional     | Subset Of         | Steering Committee & Program Oversight                                    | GOV-01.1 | Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.                                    | 10                       |       |
| 17 CFR 229.106(c)(2)(iii) | N/A      | Whether such persons or committees report information about such risks to the board of directors or a committee or subcommittee of the board of directors.                                                                                                                                                                               | Functional     | Intersects With   | Status Reporting To Governing Body                                        | GOV-01.2 | Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPI).                                                                       | 5                        |       |
| 17 CFR 229.106(d)         | N/A      | Structured Data Requirement. Provide the information required by this item in an Interactive Data File in accordance with Rule 405 of Regulation S-T and the EDGAR Filer Manual.                                                                                                                                                         | Functional     | Subset Of         | Security, Compliance & Resilience Status Reporting                        | GOV-17   | Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.                                                                                                                           | 10                       |       |
| Form 8-K Item 1.05(a)     | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Steering Committee & Program Oversight                                    | GOV-01.1 | Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.                                    | 5                        |       |
| Form 8-K Item 1.05(a)     | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Materiality Determination                                                 | GOV-16   | Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.                                                                                                                                                                                                      | 5                        |       |
| Form 8-K Item 1.05(a)     | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Contacts With Authorities                                                 | GOV-06   | Mechanisms exist to identify and document appropriate contacts with relevant law enforcement and regulatory bodies.                                                                                                                                                                                            | 5                        |       |
| Form 8-K Item 1.05(a)     | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Incident Response Operations                                              | IRO-01   | Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.                                                                                                                           | 5                        |       |

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-stm/>

Focal Document: **US - Securities and Exchange Commission (SEC) Cybersecurity Rule (2023)**

Focal Document URL: <https://www.sec.gov/files/rules/final/2023/33-11216.pdf>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-sec-cybersecurity-rule-2023.pdf>

| FDE #                 | FDE Name | Focal Document Element (FDE) Description                                                                                                                                                                                                                                                                                                 | STRM Rationale | STRM Relationship | SCF Control                                                 | SCF #    | Secure Controls Framework (SCF) Control Description                                                                                                                                                                                | Strength of Relationship | Notes |
|-----------------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|-------------------|-------------------------------------------------------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|-------|
| Form 8-K Item 1.05(a) | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Incident Handling                                           | IRO-02   | Mechanisms exist to cover:<br>(1) Preparation;<br>(2) Automated event detection or manual incident report intake;<br>(3) Analysis;<br>(4) Containment;<br>(5) Eradication; and<br>(6) Recovery.                                    | 5                        |       |
| Form 8-K Item 1.05(a) | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Incident Classification & Prioritization                    | IRO-02.4 | Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.                                                                                | 5                        |       |
| Form 8-K Item 1.05(a) | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Incident Response Plan (IRP)                                | IRO-04   | Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.                                                                                                             | 5                        |       |
| Form 8-K Item 1.05(a) | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Integrated Security Incident Response Team (ISIRT)          | IRO-07   | Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.                         | 5                        |       |
| Form 8-K Item 1.05(a) | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Incident Stakeholder Reporting                              | IRO-10   | Mechanisms exist to timely-report incidents to applicable:<br>(1) Internal stakeholders;<br>(2) Affected clients & third-parties; and<br>(3) Regulatory authorities.                                                               | 5                        |       |
| Form 8-K Item 1.05(a) | N/A      | If the registrant experiences a cybersecurity incident that is determined by the registrant to be material, describe the material aspects of the nature, scope, and timing of the incident, and the material impact or reasonably likely material impact on the registrant, including its financial condition and results of operations. | Functional     | Intersects With   | Assigned Security, Compliance & Resilience Responsibilities | GOV-04   | Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP). | 5                        |       |